

Rails middleware: path traversal

This runbook covers the operations of the rails middleware path traversal.

Overview

The main idea behind the middleware is to run a path traversal guard function on the accessed path for web requests. This way, bad actors trying to leverage a path traversal vulnerability will be detected and rejected. This follows the path traversal guidelines from the secure coding guidelines.

It will also take into account encoded characters (%2F for /) and the query parameters value (for example: `/foo?parameter=value`). Nested parameters (`/foo?param[test]=bar`) are also checked up to a depth level of 5.

Since this is a Rails middleware, the backend will:

- execute this for *all* web requests.
- execute this pretty early in the request processing (before the Rails router and several other middlewares).

If a path traversal attempt is detected,

- the request processing is interrupted and a **400 Bad Request** response with the body **Potential path traversal attempt detected..**
- the attempt is logged.

If no path traversal is detected, the request is allowed to be processed further by the Rails backend.

Controlling the behavior

The middleware is currently controlled by a single feature flag.

`check_path_traversal_middleware`. Disabling this will entirely disable the middleware and make it a no-op. Path traversal attempts will not be blocked anymore.

Dashboards & Logs

In case of an incident with this middleware, look at:

- The two **Middleware check path traversal** * dashboards in the **Rails components** panel for the current performance. It is available in the web: Overview.
 - The **Middleware check path traversal executions rate** chart will show the executions rate.
 - * This one show two lines: one for rejected requests and one for accepted requests.

- The `Middleware check path traversal execution time` Apdex chart is an Apdex chart on the execution time with a threshold of 1 ms.
 - * This dashboard only shows the accepted requests.
- The `rails_middleware_path_traversal` SLI Apdex chart shows the Apdex for the middleware which is defined as the amount of accepted requests versus the total amount of requests.
- The `rails_middleware_path_traversal` SLI Error Ratio chart shows the error ratio defined as the apdex rate for rejected requests.
- Kibana logs for a detailed report on requests detected as attempts.

Failures

Rejecting more requests than usual

The `rails_middleware_path_traversal` SLI Apdex shows the Apdex for the middleware. As stated above, for this chart, it is defined as the proportion of rejected requests over the total number of requests.

This chart is associated with a monitoring alarm. When triggered, it means that the ratio of rejected requests over all requests is larger than usual.

This can be explained by two reasons:

- The overall amount of requests is lower than usual. Since requests with path attempts are mainly automated, they can happen when the overall activity is lower, on weekends for example.
- We're receiving a very large amount of requests with path traversals. Usually, this is a sign that a automated bad actor is sending a large amount of attempts.
 - Confirm this situation by looking at the Kibana logs.
 - If confirmed, the Kibana logs provide remote ips that can be used to block specific actors.

Rejecting requests that should be accepted

Symptom: The `Middleware check path traversal executions rate` chart shows an increasing rate for rejected requests. These requests will receive a 400 `Bad Request` response.

- Check the Kibana logs and investigate the paths of the request that are rejected.
 - From the accessed paths, locate and reach the owning team to categorize the attempt as valid or not.
 - If these are genuine attempts, then we might be the target of an automated script that tries different urls with path traversal in bulks.
 - * The middleware is working as expected. However, it can be valuable to investigate if these requests come from a single originating source and block that source temporarily.

- If these are valid requests that should be accepted, this is a bug with the middleware detection logic.
 - * We could disable the middleware temporarily to solve the problem.
 - * An issue should be created to update the middleware detection logic.

Slower execution time

Symptom: The `Middleware check path traversal execution time` Apex chart shows low numbers.

This is a clear indication that the middleware is taking too much time to run the path traversal regexp.

This should be a symptom of a root cause external to the middleware.